



File No: EXP202205755

RESOLUTION OF TERMINATION OF THE PROCEDURE DUE TO VOLUNTARY PAYMENT

From the procedure initiated by the Spanish Agency for Data Protection and based on the following

BACKGROUND

FIRST: On July 12, 2023, the Director of the Spanish Agency for Data Protection agreed to initiate sanctioning proceedings against ROAMS TIC, S.L. (hereinafter, the respondent), through the Agreement transcribed below:

<<

File No: EXP202205755

AGREEMENT TO INITIATE SANCTIONING PROCEDURE

From the actions taken by the Spanish Agency for Data Protection and based on the following

FACTS

FIRST: During the period from 05/16/2022 to 09/30/2022, eight complaints were received by this Agency filed by A.A.A. (complainant 1), B.B.B. (complainant 2), C.C.C. (complainant 3), D.D.D. (complainant 4), E.E.E. (complainant 5), F.F.F. (complainant 6), G.G.G. (complainant 7), and H.H.H. (complainant 8), respectively. The complaints are directed against the entity ROAMS TIC, S.L., with NIF B34263582 (hereinafter, the respondent, claimed entity, or ROAMS TIC). The reasons for the complaints are as follows:

The complainants inform the AEPD of receiving an email from the address “****EMAIL.1”, in which alleged hackers warn (...). These communications, which were received by the complainants on May 14 and 15, 2022, are signed by “I.I.I.” and “J.J.J.”.

Complainant 2 states that they have never accessed the website of the claimed entity.

Complainant 5 requests in their complaint that the respondent, whom they claim to not know, delete all their personal data, indicating that they do not know how such data came into the possession of the claimed entity.

Complainant 6 submits their complaint due to the email received from the claimed entity, dated 06/24/2022, (...). This complaint reproduces the text of the cited email:

(...)

Complainant 7 also reports receiving the same email sent by the claimed entity on 06/25/2022.

Complainant 8 states that they became aware that the claimed entity had their email address through a communication that this entity sent informing them about a security incident. For this reason, on 07/02/2022, they exercised their right of access to know the personal data that was available in that entity and its origin, receiving a response that included their email address but associated with a name, surname, and date of birth that do not correspond to them. They insisted to the claimed entity for information about the origin of their personal data, and they were told that they had not proven that the email address belonged to complainant 8.

The following documents were submitted with the complaints:

1. (...).

(...):

(...)

In the same electronic communication, a new address is indicated, which will replace the previous one, to provide more information and/or evidence to the recipients (...).

2. (...).

3. Complainant 8 submitted the request for access to personal data made to the claimed entity and the response provided by this entity, which informs about the data that exists in its systems, the purposes of processing, the recipients, and the retention period.

SECOND: On 05/18/2022, a personal data breach was reported to the Division of Technological Innovation of this Agency by the entity ROAMS TIC, as the data controller.

In the received document, it is reported (...).

(...).

THIRD: In accordance with Article 65.4 of Organic Law 3/2018, of 5 of

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

3/19

December, on Personal Data Protection and Guarantee of Digital Rights (hereinafter LOPDGDD), upon receiving the initial complaints, the complained party was informed of the received complaints, attaching a copy of the email provided by the complaining parties, so that it could proceed with its analysis and inform this Agency within one month of the actions taken to comply with the requirements set forth in the data protection regulations.

The notification, which was carried out in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), was recorded on 06/06/2022 as evidenced by the acknowledgment of receipt in the file.

The deadline granted to ROAMS TIC elapsed without a response being received to the notification letter.

FOURTH: On 27/06/2022, the complained party submitted a new notification of a security breach addressed to the Technological Innovation Division of this Agency.

In the submitted document, it is reported (...).

(...):

. (...).

. (...).

FIFTH: On 11/11/2022, in accordance with Article 65 of the LOPDGDD, the complaint submitted by the complaining party 8 was admitted for processing.

FOURTH: The General Subdirectorate of Data Inspection proceeded to carry out preliminary investigation actions to clarify the facts in question, by virtue of the functions assigned to the control authorities in Article 57.1 and the powers granted in Article 58.1 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and in accordance with the provisions established in Title VII, Chapter I, Section two, of the LOPDGDD, being aware of the following points:

1. As "Background," the Preliminary Investigation Report highlights the following.

(...).

(...).

(...).

(...).

2. In the information obtained from ASEXOR, the complained company is a Spanish company dedicated to providing services related to information technology and computing. (...). It is also noted that its sales volume in 2021 amounted to ***AMOUNT.1.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

4/19

3. As stated on the website "***WEB.1", (...).

4. (...)

5. On 02/12/2022, a request for information was sent to the complained entity. From the response received, it is inferred:

Origin of the data from the Customer Database

(...)

Description of the facts

The entity has again submitted the report provided with the second notification of the breach. This report includes:

. (...).

. (...).

(...).

. (...).

. (...).

Cause of the breach

(...).

Communication to the affected parties

(...).

Regarding the data processor

(...).

Regarding the security measures implemented

. (...).

. (...).

. (...).

. (...).

. (...).

. (...):

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

5/19

. (...).

(...).

Information on the recurrence of these events and the number of similar events that have occurred over time.

The entity states that no similar events are known or have been recorded.

LEGAL GROUNDS

I

Competence

In accordance with the powers granted to each control authority by Article 58.2 of the GDPR and as established in Articles 47, 48.1, 64.2, and 68.1 of the LOPDGDD, the Director of the Spanish Agency for Data Protection is competent to initiate and resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states that: "The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued in its development, and, as long as they do not contradict them, subsidiarily by the general rules on administrative procedures."

II

Preliminary Issues

ROAMS TIC is a company with the legal form of a limited liability company dedicated to providing services related to information technology and computing. It has a (...).

It carries out this activity in its capacity as the data controller, as it is the one who determines the purposes and means of such activity, by virtue of Article 4.7 of the GDPR: "data controller" or "controller": the natural or legal person, public authority, service, or other body that, alone or jointly with others, determines the purposes and means of the processing; if the law of the Union or of the Member States determines the purposes and means of the processing, the controller or the specific criteria for its appointment may be established by the law of the Union or of the Member States."

An identifiable natural person is considered to be one whose identity can be determined, directly or indirectly, in particular by means of an identifier, such as a name, an identification number, location data, an online identifier, or one or several factors specific to the physical, physiological, genetic, mental, economic, cultural, or social identity of that person.

Furthermore, processing must be understood as “any operation or set of operations”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

6/19

operations carried out on personal data or sets of personal data, whether by automated procedures or not, such as collection, recording, organization, structuring, storage, adaptation or modification, extraction, consultation, use, communication by transmission, dissemination or any other form of enabling access, comparison or interconnection, limitation, deletion or destruction.”

Article 4, paragraph 12 of the GDPR broadly defines “personal data security breaches” (hereinafter security breach) as “all breaches of security that result in the accidental or unlawful destruction, loss or alteration of personal data transmitted, stored or otherwise processed, or unauthorized communication or access to such data.”

In the present case, there is a personal data security breach under the circumstances indicated in the Background, categorized as a confidentiality breach, caused by a vulnerability in the website that allowed access and exfiltration of data from the customer database of that website.

As a result of these events, the basic and contact data (name, surname, email address, and phone number) of (...) have been compromised.

According to the Article 29 Working Party (GT29), a “Confidentiality Breach” occurs when there is an unauthorized or accidental disclosure of personal data, or access to such data.

Within the principles of processing provided for in Article 5 of the GDPR, the integrity and confidentiality of personal data is guaranteed in paragraph 1.f) of Article 5 of the GDPR. In turn, the security of personal data is regulated in Article 32 of the GDPR, which governs the security of processing.

III

Article 5.1.f) of the GDPR

Article 5 of the GDPR establishes the principles that must govern the processing of personal data and mentions, among them, the principle of “integrity and confidentiality”:

“1. Personal data shall be:

(...)

f) processed in a manner that ensures appropriate security of the personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction or damage, by applying appropriate technical or organizational measures (“integrity and confidentiality”).

(...)”.

In relation to this principle, Recital 39 of the aforementioned GDPR states:

“[...] Personal data must be processed in a manner that ensures appropriate security and confidentiality of the personal data, including to prevent unauthorized access or use of such data and of the equipment used for processing.”

Taking into account the aforementioned facts, of which it is presumably...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

7/19

The party being claimed against is considered responsible, as there are sufficient indications, without prejudice to what results from the investigation, regarding a possible violation of the confidentiality principle established in Article 5.1.f) of the GDPR, “principles relating to processing,” since, as a result of the confidentiality breach, the personal data of (...) contained in its customer database were improperly exposed to third parties. (...)

This duty of confidentiality aims to prevent unauthorized leaks of personal data by their holders.

IV

Unfulfilled Obligation. Article 32 of the GDPR

Article 32 “Security of processing” of the GDPR establishes:

“1. Taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the varying likelihood and severity of risks to the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, which may include, among others:

- a) the pseudonymization and encryption of personal data;
- b) the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services;
- c) the ability to restore the availability and access to personal data quickly in the event of a physical or technical incident;
- d) a process for regularly verifying, assessing, and evaluating the effectiveness of the technical and organizational measures to ensure the security of processing.

2. In assessing the appropriateness of the level of security, particular consideration shall be given to the risks presented by the processing of data, in particular as a result of the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data.

3. Adherence to an approved code of conduct pursuant to Article 40 or to an approved certification mechanism pursuant to Article 42 may serve as an element to demonstrate compliance with the requirements set out in paragraph 1 of this article.

4. The controller and the processor shall take measures to ensure that any person acting under the authority of the controller or the processor and having access to personal data may only process such data on instructions from the controller, unless required to do so by Union or Member State law.”

Article 32 does not establish static security measures; rather, it is up to controllers and processors to determine the security measures necessary to ensure the confidentiality, integrity, and availability of personal data. Therefore, the same data processing may involve different security measures depending on the specificities in which it occurs.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

8/19

place of said data processing.

In accordance with these provisions, Recital 75 of the GDPR states:

“(75) The risks to the rights and freedoms of natural persons, of varying severity and probability, may arise from data processing that could cause physical, material, or immaterial harm, particularly in cases where the processing may lead to issues of discrimination, identity theft or fraud, financial losses, damage to reputation, loss of confidentiality of data subject to professional secrecy, unauthorized reversal of pseudonymization, or any other significant economic or social harm; in cases where data subjects are deprived of their rights and freedoms or prevented from exercising control over their personal data; in cases where the personal data processed reveal ethnic or racial origin, political opinions, religion or philosophical beliefs, trade union membership, and the processing of genetic data, data concerning health or data about sexual life, or criminal convictions and related security measures; in cases where personal aspects are evaluated, in particular the analysis or prediction of aspects related to work performance, economic situation, health, personal preferences or interests, reliability or behavior, situation or movements, in order to create or use personal profiles; in cases where personal data of vulnerable individuals, particularly children, are processed; or in cases where the processing involves a large amount of personal data and affects a large number of data subjects.”

Furthermore, Recital 83 of the GDPR states:

“(83) In order to maintain security and prevent processing from infringing the provisions of this Regulation, the controller or processor must assess the inherent risks of the processing and implement

measures to mitigate them, such as encryption. These measures must ensure an adequate level of security, including confidentiality, taking into account the state of the art and the cost of their implementation in relation to the risks and the nature of the personal data that must be protected. When assessing the risk in relation to data security, the risks arising from the processing of personal data must be considered, such as the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data, which may in particular cause physical, material, or immaterial harm.”

Ultimately, the first step in determining security measures will be the risk assessment. Once assessed, it will be necessary to determine the security measures aimed at reducing or eliminating risks related to data processing.

Data security requires the implementation of appropriate technical or organizational measures for the processing of personal data to protect such data against access, use, modification, dissemination, loss, destruction, or accidental, unauthorized, or unlawful damage. In this regard, security measures are key to ensuring the fundamental right to data protection. The existence of the fundamental right to the protection of personal data is not possible if confidentiality, integrity, and availability of such data cannot be guaranteed.

It should not be forgotten that, in accordance with Article 32.1 of the aforementioned GDPR, the technical and organizational measures to be applied to ensure an adequate level of security relative to the risk must take into account the state of the art, the costs of...

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
9/19

application, the nature, scope, context, and purposes of the processing, as well as the risks of varying probability and severity for the rights and freedoms of individuals.

Due to the activity it engages in, the respondent is obliged to carry out a highly specialized risk analysis and implement appropriate technical and organizational measures to ensure a level of security adequate to the risk of its activity for the rights and freedoms of individuals.

Therefore, the respondent, when assessing the risks and determining the appropriate technical and organizational measures to ensure a level of security adequate to the risk for the rights and freedoms of individuals regarding the data processing it performs, is obliged to take into account the specific activity that constitutes its business, which involves continuously and on a large scale processing personal data (numerous data to be collected, processed, stored...); the type of data processed: including identification data, contact data, those related to ID numbers and dates of birth, income, and financial data; or the context: existence of web applications on the internet, that is, in a non-isolated environment, which entails risks derived from the very interconnectivity that the network implies, which must be addressed in a specialized manner.

(...).

(...).

(...).

(...).

(...).

All of the above demonstrates that the respondent did not have the appropriate security measures in place to ensure that a security incident, such as the one that occurred in this case, did not take place, that is, it did not apply appropriate technical and organizational measures to ensure a level of security adequate to the risk of its personal data processing, resulting in a lack of diligence on the part of the respondent, as the responsible entity, in preventing unauthorized access by third parties.

Evidence that the information systems of the respondent did not have adequate measures is the measures adopted following the confirmed security incident, among which are some that are considered basic to ensure the security of personal data, such as the implementation of a (...).

Therefore, in accordance with the evidence available at this moment in the initiation of sanctioning procedure agreement, and without prejudice to what results from the instruction, it is considered that

the known facts could constitute an infringement, attributable to the respondent, for violation of Article 32 of the GDPR.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

10/19

V

Classification and qualification of the infringements

The non-compliance with the provisions established in Article 5.1.f) of the GDPR constitutes the commission of an infringement classified in section 5.a) of Article 83 of the GDPR, which under the heading "General conditions for the imposition of administrative fines" states the following:

"5. Infringements of the following provisions shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to 20,000,000 EUR or, in the case of an enterprise, an amount equivalent to a maximum of 4% of the total annual global turnover of the previous financial year, opting for the higher amount:

a) the basic principles for processing, including the conditions for consent under Articles 5, 6, 7, and 9."

For its part, the LOPDGDD in its Article 71, Infringements, states that:

"Acts and behaviors referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those contrary to this organic law, constitute infringements."

For the purposes of the statute of limitations, Article 72 of the LOPDGDD indicates:

"Article 72. Very serious infringements.

1. Based on what is established in Article 83.5 of Regulation (EU) 2016/679, the following infringements are considered very serious and shall be subject to a three-year statute of limitations, which involve a substantial violation of the articles mentioned therein and, in particular, the following:

a) The processing of personal data violating the principles and guarantees established in Article 5 of Regulation (EU) 2016/679."

On the other hand, the violation of Article 32 of the GDPR is classified in Article 83.4.a) of the aforementioned GDPR in the following terms:

"4. Infringements of the following provisions shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to 10,000,000 EUR or, in the case of an enterprise, an amount equivalent to a maximum of 2% of the total annual global turnover of the previous financial year, opting for the higher amount:

a) the obligations of the controller and the processor under Articles 8, 11, 25 to 39, 42, and 43. (...)."

And Article 73 of the LOPDGDD, for the purposes of the statute of limitations, qualifies as "Serious Infringements":

"Based on what is established in Article 83.4 of Regulation (EU) 2016/679, the following infringements are considered serious and shall be subject to a two-year statute of limitations, which involve a substantial violation of the articles mentioned therein and, in particular, the following:

(...)

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

11/19

f) The failure to adopt those technical and organizational measures that are appropriate to ensure a level of security adequate to the risk of the processing, as required by Article 32.1 of Regulation (EU) 2016/679."

(...)

VI

Corrective Powers

In the event of a violation of the provisions of the GDPR, among the corrective powers available to the Spanish Agency for Data Protection, as the supervisory authority, Article 58.2 of said Regulation includes the following:

“2 Each supervisory authority shall have all of the following corrective powers:

(...)

b) issue a warning to any controller or processor when the processing operations have infringed the provisions of this Regulation;”

(...)

d) order the controller or processor to bring the processing operations into compliance with the provisions of this Regulation, when appropriate, in a specified manner and within a specified time;

(...)

i) impose an administrative fine in accordance with Article 83, in addition to or instead of the measures mentioned in this paragraph, depending on the circumstances of each particular case;.”

According to the provisions of Article 83.2 of the GDPR, the measure provided for in the previous paragraph d) is compatible with the sanction consisting of an administrative fine.

VII

Proposal for Sanction

With respect to the violations of Articles 32 and 5.1.f) of the GDPR, taking into account the facts presented and without prejudice to the outcome of the procedure's instruction, it is considered that the sanction to be imposed is an administrative fine.

In order to determine the administrative fine to be imposed, the provisions of Articles 83.1 and 83.2 of the GDPR must be observed, which state:

“1. Each supervisory authority shall ensure that the imposition of administrative fines under this article for the infringements of this Regulation indicated in paragraphs 4, 9, and 6 are, in each individual case, effective, proportionate, and dissuasive.

2. Administrative fines shall be imposed, depending on the circumstances of each individual case, as an additional or substitute measure to those contemplated in Article 58, paragraph 2, letters a) to h) and j). In deciding on the imposition of an administrative fine and its amount in each individual case, the following shall be duly taken into account:

a) the nature, gravity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation in question as well as the number of data subjects affected and the level of damage and harm they have suffered;

b) the intentionality or negligence in the infringement;

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

12/19

c) any measures taken by the data controller or processor to mitigate the damages suffered by the data subjects;

d) the degree of responsibility of the data controller or processor, taking into account the technical or organizational measures they have implemented pursuant to Articles 25 and 32;

e) any prior infringement committed by the data controller or processor;

f) the degree of cooperation with the supervisory authority in order to remedy the infringement and mitigate the possible adverse effects of the infringement;

g) the categories of personal data affected by the infringement;

h) the manner in which the supervisory authority became aware of the infringement, particularly whether the data controller or processor notified the infringement and, if so, to what extent;

i) when the measures indicated in Article 58, paragraph 2, have been previously ordered against the data controller or processor in relation to the same matter, compliance with such measures;

j) adherence to codes of conduct under Article 40 or to certification mechanisms approved under Article 42; and

k) any other aggravating or mitigating factor applicable to the circumstances of the case, such as

financial benefits obtained or losses avoided, directly or indirectly, through the infringement.”

For its part, Article 76 “Sanctions and corrective measures” of the LOPDGDD states:

“1. The sanctions provided for in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679 shall be applied taking into account the criteria for graduation established in paragraph 2 of the aforementioned article.

2. In accordance with the provisions of Article 83.2.k) of Regulation (EU) 2016/679, the following may also be taken into account:

- a) The ongoing nature of the infringement.
- b) The connection of the infringer's activity with the processing of personal data.
- c) The benefits obtained as a result of the commission of the infringement.
- d) The possibility that the conduct of the affected party may have induced the commission of the infringement.
- e) The existence of a merger by absorption after the commission of the infringement, which cannot be attributed to the absorbing entity.
- f) The impact on the rights of minors.
- g) Having, when not mandatory, a data protection officer.
- h) The voluntary submission by the data controller or processor to alternative dispute resolution mechanisms, in cases where there are disputes between them and any data subject.”

In this case, considering the severity of the established infringements, particularly regarding the volume of personal data involved in the identified incident, the imposition of a fine is warranted, in addition to the adoption of measures, if applicable.

The fine imposed must be, in each individual case, effective, proportionate, and dissuasive, in accordance with the provisions of Article 83.1 of the GDPR. Thus, the condition of a small enterprise and the turnover of the party being claimed is considered in advance (...).

In accordance with the indicated provisions, based on the evidence available at this moment regarding the initiation of sanctioning proceedings and without prejudice to what results from the instruction of the procedure, for the purpose of establishing the

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

13/19

the amount of the sanctions to be imposed in this case, it is considered appropriate to graduate the sanctions according to the following criteria established by the transcribed provisions:

1. Violation of Article 5.1.f) of the GDPR, classified under Article 83.5.a) of the aforementioned Regulation, and qualified as very serious for the purposes of prescription in Article 72.1.a) of the LOPDGDD:

In an initial assessment, the following aggravating criteria for graduation are deemed concurrent:

. Article 83.2.a) of the GDPR: “a) the nature, gravity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation in question as well as the number of affected parties and the level of damage and harm they have suffered.”

× It is considered that the nature of the infringement is serious since it has resulted in a loss of confidentiality and, therefore, of irremediable disposition and control over personal data, (...).

. Regarding the duration of the infringement, (...).

× The number of affected parties amounts to (...) users of the entity's website.

. The nature of the harm caused to the affected individuals, who have seen an increased risk to their privacy, as they lost all control over their personal data, which poses a high risk of fraudulent use, thereby undermining the fundamental right to personal data protection that, as indicated by the Constitutional Court, aims to guarantee individuals control and disposition over their personal data, its use and destination, with the purpose of preventing its illicit and harmful trafficking to the dignity and rights of the affected party.

. Article 83.2.b) of the GDPR: “b) the intentionality or negligence in the infringement.”

In this case, the negligence of the accused party in complying with and observing the technical and

organizational measures necessary to ensure the security required for the protection of personal data, specifically to guarantee the confidentiality of such data, must be classified as "serious," as they had not implemented the relevant security measures despite the incident being caused by a publicly known vulnerability.

In this regard, the statement made in the Judgment of the National Court of 17/10/2007 (rec. 63/2006) is taken into account, which, starting from the fact that these are entities whose activity involves continuous data processing, indicates that "...the Supreme Court has understood that there is recklessness whenever a legal duty of care is neglected, that is, when the infringer does not behave with the required diligence. And in assessing the degree of diligence, the professionalism or lack thereof of the subject must be especially weighed, and there is no doubt that, in the case now examined, when the activity of the appellant involves constant and abundant handling of personal data, it must be insisted upon the rigor and exquisite care to comply with the legal provisions in this regard."

The accused party systematically processes personal data related to health and must exercise utmost care in fulfilling its obligations in protecting such data.

This Agency understands that diligence must be deduced from conclusive facts that are duly accredited and directly related to the elements that constitute the infringement, in such a way that it can be inferred that it occurred despite all the means provided by the responsible party to prevent it. In this case, the actions of the accused party do not have this character.

. Article 76.2.b) of the LOPDGDD: "(b) The link of the infringer's activity with the performance of personal data processing."

The high link of the accused party's activity with the performance of personal data processing, considering the activity it develops.

Considering the factors presented, the initial assessment of the fine for the infringement of Article 5.1.f) of the GDPR is 30,000 euros (thirty thousand euros).

2. Violation of Article 32 of the GDPR, classified under Article 83.4.a) of the aforementioned GDPR, and qualified as serious for the purposes of prescription in Article 73.f) of the GDPR:

In an initial assessment, the same aggravating criteria for graduation indicated in the previous section are deemed concurrent.

Considering the factors presented, the initial assessment of the fine for the infringement of Article 32 of the GDPR is 20,000 euros (twenty thousand euros).

VIII

Adoption of measures

If the infringement is confirmed, it could be agreed to impose on the responsible party the adoption of appropriate measures to adjust its actions to the regulations mentioned in this act, in accordance with what is established in the aforementioned Article 58.2 d) of the GDPR, according to which each supervisory authority may "order the controller or processor to ensure that the processing operations comply with the provisions of this Regulation, where appropriate, in a specific manner and within a specified time frame...". The imposition of this measure is compatible with the sanction consisting of an administrative fine, as provided in Article 83.2 of the GDPR.

In such a case, in the resolution that is adopted, this Agency may require the responsible entity to, within the determined timeframe, adjust its actions to the personal data protection regulations, to the extent expressed in the Legal Grounds of this agreement and without prejudice to what results from the

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

15/19

instruction.

However, in this regard, it is noted that the party being claimed has stated that (...).

It is warned that failure to comply with the possible order to adopt measures imposed by this body in the sanctioning resolution may be considered an administrative infringement in accordance with the

provisions of the GDPR, classified as an infringement in its articles 83.5 and 83.6, which may lead to the initiation of further administrative sanctioning proceedings.

Therefore, in light of the above, by the Director of the Spanish Agency for Data Protection,
IT IS AGREED:

FIRST: TO INITIATE SANCTIONING PROCEDURE against ROAMS TIC, S.L., with NIF B34263582, for the following alleged infringements:

- for the alleged infringement of article 5.1.f) of the GDPR, classified in accordance with the provisions of article 83.5 of the GDPR, qualified as very serious for the purposes of prescription in article 72.1.a) of the LOPDGDD.
- for the alleged infringement of article 32 of the GDPR, classified in accordance with the provisions of article 83.4 of the GDPR, qualified as serious for the purposes of prescription in article 73.f) of the LOPDGDD.

SECOND: TO APPOINT K.K.K. as instructor and L.L.L. as secretary, indicating that they may be challenged, if applicable, in accordance with the provisions of articles 23 and 24 of Law 40/2015, of October 1, on the Legal Regime of the Public Sector (LRJSP).

THIRD: TO INCORPORATE into the sanctioning file, for evidentiary purposes, the complaints filed by the claiming parties and their documentation, as well as the documents obtained and generated by the General Subdirectorate for Data Inspection in the proceedings prior to the initiation of this sanctioning procedure.

FOURTH: THAT for the purposes provided in art. 64.2 b) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations, the sanction that may correspond, without prejudice to what results from the instruction, would be:

. For the alleged infringement of article 5.1.f) of the GDPR, classified in article 83.5.a) of the same Regulation, a sanction in the amount of 30,000 euros (thirty thousand euros).

. For the alleged infringement of article 32 of the GDPR, classified in article 83.4.a) of the same Regulation, a sanction in the amount of 20,000 euros (twenty thousand euros).

FIFTH: TO NOTIFY this agreement to ROAMS TIC, S.L., with NIF B34263582, granting a hearing period of ten working days for them to submit allegations and present any evidence they deem appropriate. In their written allegations, they must provide their NIF and the file number that appears in the heading of this document.

If they do not submit allegations to this initiation agreement within the stipulated period, it may be considered a proposal for resolution, as established in article 64.2.f) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP).

In accordance with the provisions of article 85 of the LPACAP, they may acknowledge their responsibility within the period granted for submitting allegations to this initiation agreement; this will entail a reduction of 20% of the sanction that may be imposed in this procedure. With the application of this reduction, the sanction would be set at 40,000 euros (forty thousand euros), resolving the procedure with the imposition of this sanction.

Similarly, they may, at any time prior to the resolution of this procedure, voluntarily pay the proposed sanction, which will imply a reduction of 20% of its amount. With the application of this reduction, the sanction would be set at 40,000 euros (forty thousand euros) and its payment will imply the termination of the procedure, without prejudice to the imposition of the corresponding measures.

The reduction for the voluntary payment of the sanction is cumulative with the one corresponding to the acknowledgment of responsibility, provided that this acknowledgment of responsibility is made within the period granted to submit allegations to the opening of the procedure. The voluntary payment of the amount referred to in the previous paragraph may be made at any time prior to the resolution. In this case, if both reductions are applicable, the amount of the sanction would be set at 30,000 euros (thirty thousand euros).

In any case, the effectiveness of either of the two mentioned reductions will be conditioned upon the withdrawal or renunciation of any action or administrative appeal against the sanction.

In the event that they choose to proceed with the voluntary payment of any of the amounts indicated above (40,000 euros or 30,000 euros), they must do so by depositing it into account no. IBAN:

ES00-0000-0000-0000-0000 (BIC/SWIFT Code: CAIXESBBXXX) opened in the name of the Spanish Agency for Data Protection at the banking entity CAIXABANK, S.A., indicating in the concept the reference number of the procedure that appears in the heading of this document and the reason for the reduction of the amount to which they are adhering.

They must also send the proof of payment to the General Subdirectorate for Inspection to continue with the procedure in accordance with the amount deposited.

The procedure will have a maximum duration of twelve months from the date of the initiation agreement. After this period, it will expire, and consequently, the file will be archived; in accordance with the provisions of article 64 of the LOPDGDD.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

17/19

Finally, it is noted that according to the provisions of Article 112.1 of the LPACAP, there is no administrative appeal against this act.

935-290523

Mar España Martí

Director of the Spanish Agency for Data Protection

>>

SECOND: On July 21, 2023, the respondent has proceeded to pay the fine in the amount of 30,000 euros, making use of the two reductions provided for in the previously transcribed Initiation Agreement, which implies the acknowledgment of responsibility.

THIRD: The payment made, within the period granted to submit allegations regarding the opening of the procedure, entails the waiver of any action or administrative appeal against the fine and the acknowledgment of responsibility concerning the facts referred to in the Initiation Agreement.

FOURTH: In the aforementioned Initiation Agreement transcribed earlier, it was indicated that if the infringement were confirmed, it could be agreed to impose on the responsible party the adoption of appropriate measures to adjust their actions to the regulations mentioned in this act, in accordance with the provisions of Article 58.2 d) of the GDPR, according to which each supervisory authority may “order the controller or processor to ensure that the processing operations comply with the provisions of this Regulation, where appropriate, in a specific manner and within a specified period...”.

Having received a written communication from ROAMS TIC, S.L. informing that it has adopted the necessary measures to prevent the recurrence of the facts that led to the infringement, this Agency acknowledges receipt of the same, without this declaration implying any pronouncement on the regularity or legality of the measures adopted.

It is warned about the provisions of Article 5.2 of the GDPR, which establishes the principle of proactive responsibility when it states that “The controller shall be responsible for compliance with the provisions of paragraph 1 and be able to demonstrate it.” This principle refers to the obligation that falls on the controller not only to design, implement, and observe the appropriate legal, technical, and organizational measures so that data processing is in accordance with the regulations but also to remain actively vigilant throughout the entire lifecycle of the processing to ensure that such compliance is correct, being additionally able to demonstrate it.

LEGAL GROUNDS

I

Competence

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

18/19

In accordance with the powers granted to each supervisory authority by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and as established in Articles 47, 48.1, 64.2, and 68.1 of Organic Law 3/2018, of December 5, on the Protection of Personal Data and guarantee of digital rights (hereinafter, LOPDGDD), the Director of the Spanish Agency for Data Protection is competent to initiate and resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states that: "The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued in its development, and, in so far as they do not contradict them, subsidiarily by the general rules on administrative procedures."

II

Termination of the procedure

Article 85 of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), under the heading "Termination in sanctioning procedures" provides as follows:

"1. Once a sanctioning procedure has been initiated, if the offender acknowledges their responsibility, the procedure may be resolved with the imposition of the appropriate sanction.

2. When the sanction is solely of a pecuniary nature or when it is possible to impose a pecuniary sanction and another non-pecuniary sanction but the impropriety of the latter has been justified, voluntary payment by the alleged responsible party, at any time prior to the resolution, will imply the termination of the procedure, except regarding the restoration of the altered situation or the determination of compensation for damages caused by the commission of the infringement.

3. In both cases, when the sanction is solely of a pecuniary nature, the competent authority to resolve the procedure shall apply reductions of at least 20% on the amount of the proposed sanction, which shall be cumulative. The aforementioned reductions must be specified in the notification of initiation of the procedure, and their effectiveness shall be conditioned upon the withdrawal or waiver of any action or administrative appeal against the sanction. The percentage of reduction provided for in this section may be increased by regulation."

In accordance with the above,

the Director of the Spanish Agency for Data Protection RESOLVES:

FIRST: TO DECLARE the termination of procedure EXP202205755, in accordance with the provisions of Article 85 of the LPACAP.

SECOND: TO NOTIFY this resolution to ROAMS TIC, S.L..

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

19/19

In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Against this resolution, which concludes the administrative procedure as provided by Article 114.1.c) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations, the interested parties may file a contentious-administrative appeal before the Contentious-Administrative Chamber of the National Court, in accordance with the provisions of Article 25 and Section 5 of the fourth additional provision of Law 29/1998, of July 13, regulating the Contentious-Administrative Jurisdiction, within a period of two months from the day following the notification of this act, as provided in Article 46.1 of the aforementioned Law.

1219-181022

Mar España Martí

Director of the Spanish Agency for Data Protection

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es